

Security Assessment Findings Report for demo.testfire.net

CIN ID: FIT/APR26/CS7733

Date: 09/05/2026

Project: FUTURE_CS_01



ONLINE BANKING LOGIN	PERSONAL	SMALL BUSINESS	INSIDE ALTORO MUTUAL
PERSONAL - Deposit Product - Checking - Loan Products - Cards - Investments & Insurance - Other Services SMALL BUSINESS - Deposit Products - Lending Services - Cards - Insurance - Retirement - Other Services INSIDE ALTORO MUTUAL - About Us - Contact Us - Locations - Investor Relations - Press Room - Careers - Subscribe	Online Banking with FREE Online Bill Pay No stamps, envelopes, or checks to write give you more time to spend on the things you enjoy.  Real Estate Financing Fast. Simple. Professional. Whether you are preparing to buy, build, purchase land, or construct new space, let Altoro Mutual's premier real estate lenders help with financing. As a regional leader, we know the market, we understand the business, and we have the track record to prove it.	 Business Credit Cards You're always looking for ways to improve your company's bottom line. You want to be informed, improve efficiency and control expenses. Now, you can do it all - with a business credit card account from Altoro Mutual. Retirement Solutions Retaining good employees is a tough task. See how Altoro Mutual can assist you in accomplishing this feat through effective Retirement Solutions.	Privacy and Security The 2000 employees of Altoro Mutual are dedicated to protecting your privacy and security . We pledge to provide you with the information and resources that you need to help secure your information and keep it confidential. This is our promise.  Win a Samsung Galaxy S10 smartphone Completing this short survey will enter you in a draw for 1 of 5 Samsung Galaxy S10 smartphones! We look forward to hearing your important feedback.

Privacy Policy | Security Statement | Server Status Check | BEST API | © 2026 Altoro Mutual, Inc.

This web application is open source! Get your copy from [Github](#) and take advantage of advanced features

The Altoro website is published by HCL Technologies, Ltd. for the sole purpose of demonstrating the effectiveness of HCL products in detecting web application vulnerabilities and website defects. This site is not a real banking site. Similarities, if any, to third party products and/or websites are purely coincidental. This site is provided "as is" without warranty of any kind, either express or implied. HCL does not assume any risk in relation to your use of this website. For more information, please go to <https://www.hcl-software.com/apocani/>.

Copyright © 2008, 2017, IBM Corporation, All rights reserved. Copyright © 2017, 2026, HCL Technologies, Ltd., All rights reserved.

Table of Contents

Confidentiality Statement	5
Disclaimer	5
Contact Information	5
Assessment Overview.....	6
Assessment Components	6
Finding Severity Ratings	7
Scope	7
Executive Summary	8
Attack Summary	9
Penetration Test Findings:	10
1) Reflected Cross-Site Scripting (High).....	10
2) SQL Injection (High)	11
3) PII Disclosure (High).....	12
4) Default Credentials Accepted (High).....	14
5) Missing Security Headers (Medium)	15
6) Absence of Anti-CSRF Tokens (Medium)	17
7) Missing Anti-Clickjacking Header (Medium)	17
8) Cookie Without SameSite Attribute (Medium)	18
9) No HTTPS / TLS Encryption (Low)	19
10) Server Version Disclosure (Low)	19
11) Verbose Login Error Message (Low)	20
Network Scan Result(Nmap).....	21
Security Weakness Summary	23

Tools Used

OWASP ZAP

Used to identify web application vulnerabilities such as missing security headers, CSRF issues, and other risks.

Nmap

Used to discover open ports, running services, and network exposure.

Browser DevTools

Used to inspect HTML elements, analyze HTTP headers, and examine cookies.

Canva

Used to design and format the final professional report.

Confidentiality Statement

This document is produced solely for the Future Interns Cyber Security Internship program. It contains findings from a security assessment on a deliberately vulnerable demo application. This document may be shared with internship reviewers and evaluators only.

Disclaimer

A security assessment is a snapshot in time. The findings reflect the state of the application at the time of testing. The target (demo.testfire.net) is a deliberately vulnerable demo application by HCL Technologies Ltd. for security training only. No real users, real data, or production systems were affected. All testing was read-only and non-intrusive.

Contact Information

NAME	TITLE	CONTACT
NISHANTH N NAIK	Security Assessor	nishanthnaik15@gmail.com
FUTURE INTERNS	Organization	contact@futureinterns.com

Assessment Overview

From 9 May 2026, a passive vulnerability assessment was conducted on the web application at <http://demo.testfire.net>. All testing was based on the OWASP Testing Guide (v4) methodology. Phases included:

- Planning — Defined scope and selected tools
- Discovery — Passive scanning with OWASP ZAP and Browser DevTools.
- Manual Testing — Tested login, search bar, and feedback forms .
- Reporting — Documented all findings with evidence and remediation steps.

Assessment Components

External Penetration Test A passive web application assessment was performed simulating an external attacker with no prior knowledge of the application. OWASP ZAP automated scanning and manual browser-based testing were used to identify vulnerabilities without modifying any data.

Finding Severity Ratings

Severity	Definition	Action
High	Straightforward exploitation, data loss or unauthorized access possible	Patch immediately
Medium	Requires extra steps, could expose sensitive functionality	Patch after High
Low	Non-exploitable, reduces attack surface	Patch at next window
Informational	No vulnerability, additional context only	Review and monitor

Scope

Assessment	Details
Passive web application test	http://demo.testfire.net

Executive Summary

A passive vulnerability assessment was conducted on <http://demo.testfire.net> on 9 May 2026 using OWASP ZAP 2.17.0 and Browser DevTools. The automated scan detected 22 alerts. Manual testing additionally confirmed XSS, SQL injection, and default credential access. It is strongly recommended that all High severity findings be fixed immediately as they allow full unauthorized access to banking functionality.

Total alerts	High	Low	Medium	Informational
22	3	5	9	5

ZAP by Checkmarx

Altoro Mutual Vulnerability Assessment

Sites: <https://firefox-settings-attachments.cdn.mozilla.net> <https://firefox.settings.services.mozilla.com> <http://demo.testfire.net>

Generated on Sat, 9 May 2026 22:23:16

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	3
Medium	5
Low	9
Informational	5

Insights

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP warnings logged - see the zap.log file for details	47
Low	Exceeded High	http://demo.testfire.net	Percentage of slow responses	100 %
Info	Informational		Percentage of network failures	1 %
Info	Informational	http://demo.testfire.net	Percentage of responses with status code 2xx	70 %
Info	Informational	http://demo.testfire.net	Percentage of responses with status code 3xx	5 %
Info	Exceeded Low	http://demo.testfire.net	Percentage of responses with status code 4xx	23 %
Info	Informational	http://demo.testfire.net	Percentage of endpoints with content type application/javascript	1 %
Info	Informational	http://demo.testfire.net	Percentage of endpoints with content type application/json	6.4 %

29°

Search

ENG IN 10:24 PM 5/9/2026

Attack Summary

NO	FINDING	Recommendation	Severity
1	Reflected XSS in search and feedback	Encode all output, add CSP header	High
2	SQL Injection on login form	Use parameterized queries	High
3	PII Disclosure in HTTP responses	Mask sensitive data in responses	High
4	Default credentials accepted	Disable defaults, enforce MFA	High
5	Missing security headers	Add CSP, HSTS, X-Frame-Options	Medium
6	No Anti-CSRF tokens	Add CSRF token to all forms	Medium
7	Missing anti-clickjacking header	Add X-Frame-Options: DENY	Medium
8	Cookie without SameSite attribute	Add SameSite=Strict, Secure flag	Medium
9	No HTTPS encryption	Install TLS certificate	Low
10	Server version disclosure	Set ServerTokens Prod	Low
11	Verbose login error message	Use generic error message	Low

Finding 1

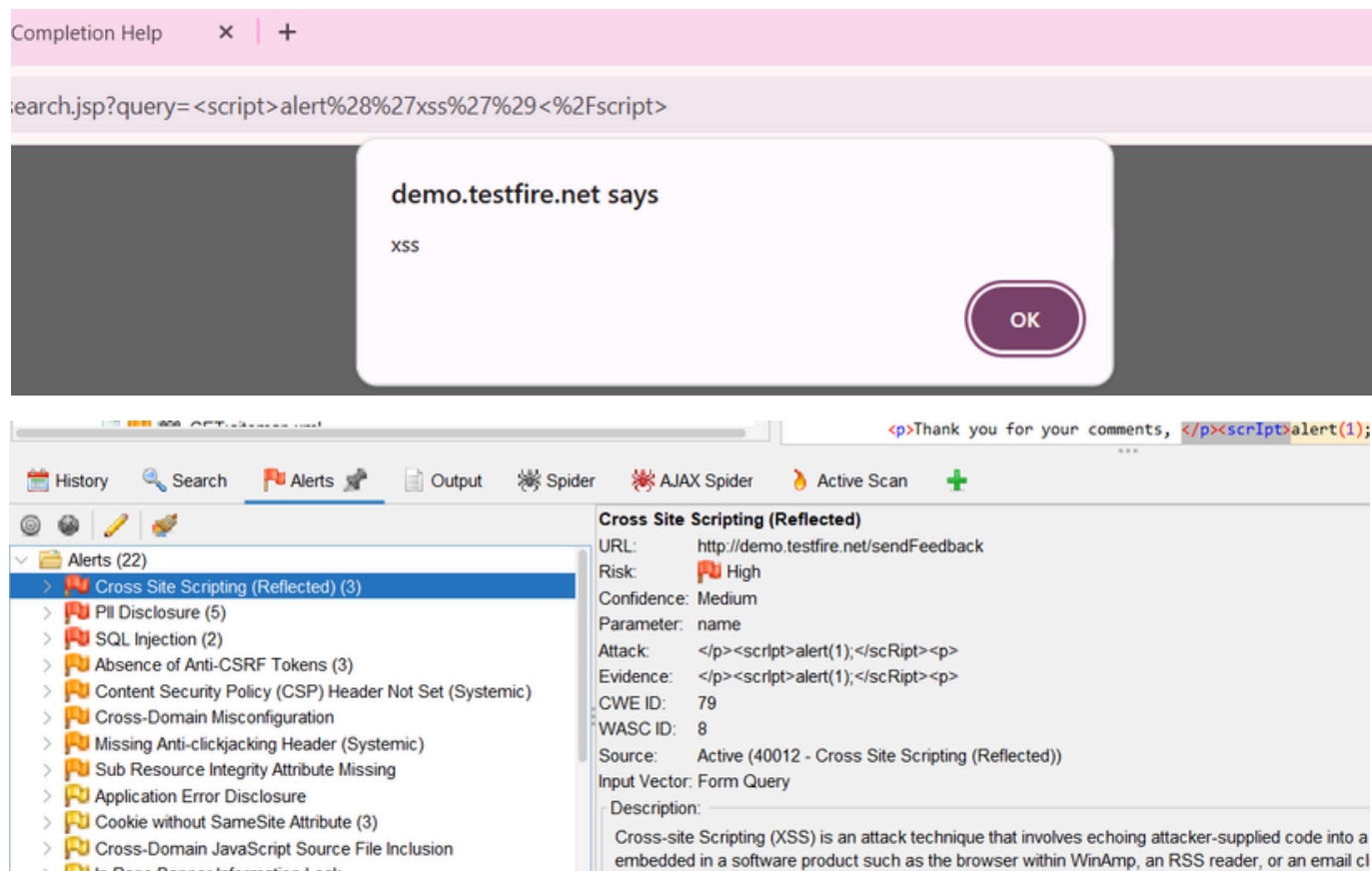
Reflected Cross-Site Scripting (High)

Description

The search bar at search.jsp and the feedback form at sendFeedback reflect user-supplied input directly into the page without HTML encoding. Injecting a script tag causes it to execute in the victim's browser. An attacker can steal session cookies, hijack accounts, or redirect users to malicious sites.

Impact -High

System - <http://demo.testfire.net/search.jsp>



Recommendation:

- Encode all user-supplied output using HTML escaping (htmlspecialchars() in PHP)
- Add Content-Security-Policy header
- Add X-XSS-Protection header
- Use a Web Application Firewall (WAF)
- Validate all input server-side

Finding 2

SQL Injection (High)

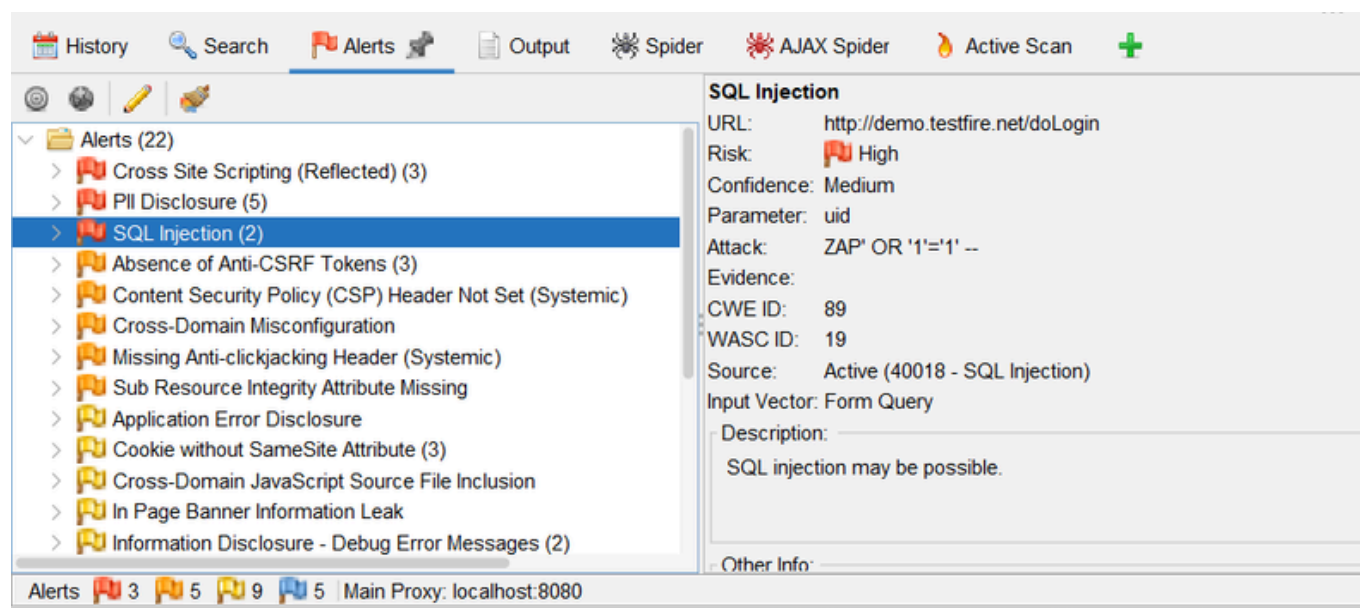
Description

The login form's uid parameter passes user input directly into SQL queries without parameterization. ZAP confirmed this using the payload ZAP' OR '1'='1' -
-. An attacker can bypass login authentication or extract the entire database.

Impact - High

System - <http://demo.testfire.net/doLogin>

Proof of Concept:



Recommendation:

- Use parameterized queries (prepared statements) for all database interactions
- Validate and sanitize all user inputs
- Apply least privilege to database accounts
- Never expose SQL errors to users
- Use an ORM that handles escaping

Finding 3

PII Disclosure (High)

Description

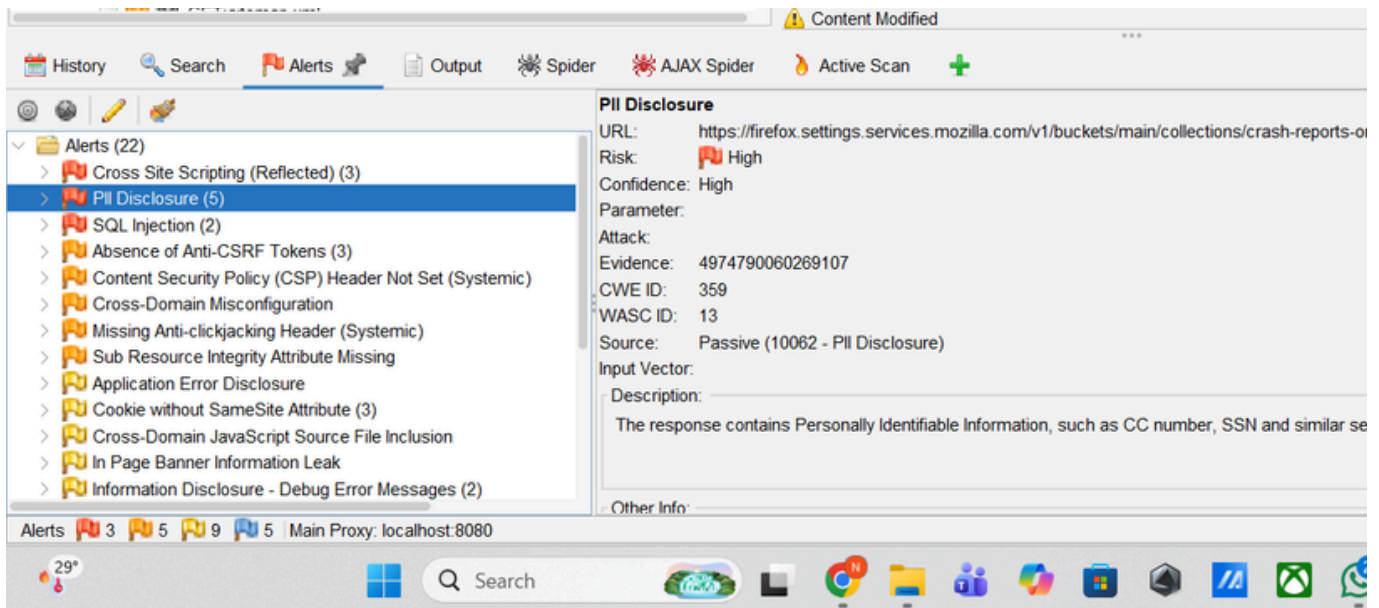
OWASP ZAP passive scan detected that HTTP responses contain Personally Identifiable Information including credit card numbers and SSN-like data. For a banking application

this is a critical data privacy violation

Impact -High

System - <http://demo.testfire.net> (HTTP responses)

Proof of Concept:



Recommendation:

- Remove all PII from HTTP responses
- Mask card numbers (show last 4 digits only)
- Implement data minimization policy
- Encrypt sensitive data at rest and in transit
- Audit all data flows for PII exposure

Finding 4

Default Credentials Accepted (High)

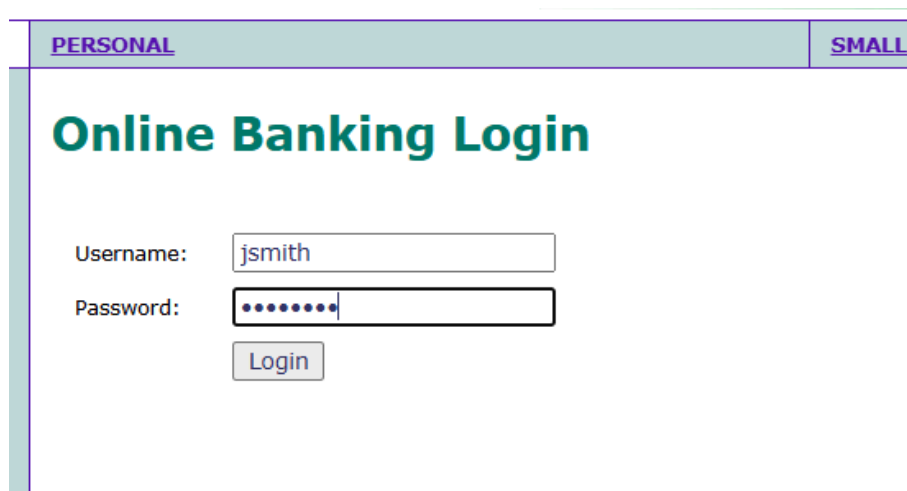
Description

The application accepts admin/admin credentials with no account lockout, no MFA, and no CAPTCHA. Full authenticated access to the banking dashboard was obtained including account details and fund transfer options.

Impact - High

System - <http://demo.testfire.net/login.jsp>

Proof of Concept:



The Altoro website is published by HCL Technologies, Ltd. for the sole purpose of demonstrating the effectiveness of HCL products in detecting web application vulnerabilities and website defects. This site is not a real banking site. Similarities, if any, to third party products and/or websites are purely coincidental. This site is provided "as is" without warranty of any kind, either express or implied. HCL does not assume any risk in relation to your use of this website. For more information, please go to <https://www.hcl-software.com/opensource/>.

Recommendation:

- Disable all default credentials immediately
- Force password change on first login
- Implement MFA for all accounts
- Add account lockout after 5 failed attempts
- Add CAPTCHA to the login page

Finding 5

Missing Security Headers (Medium)

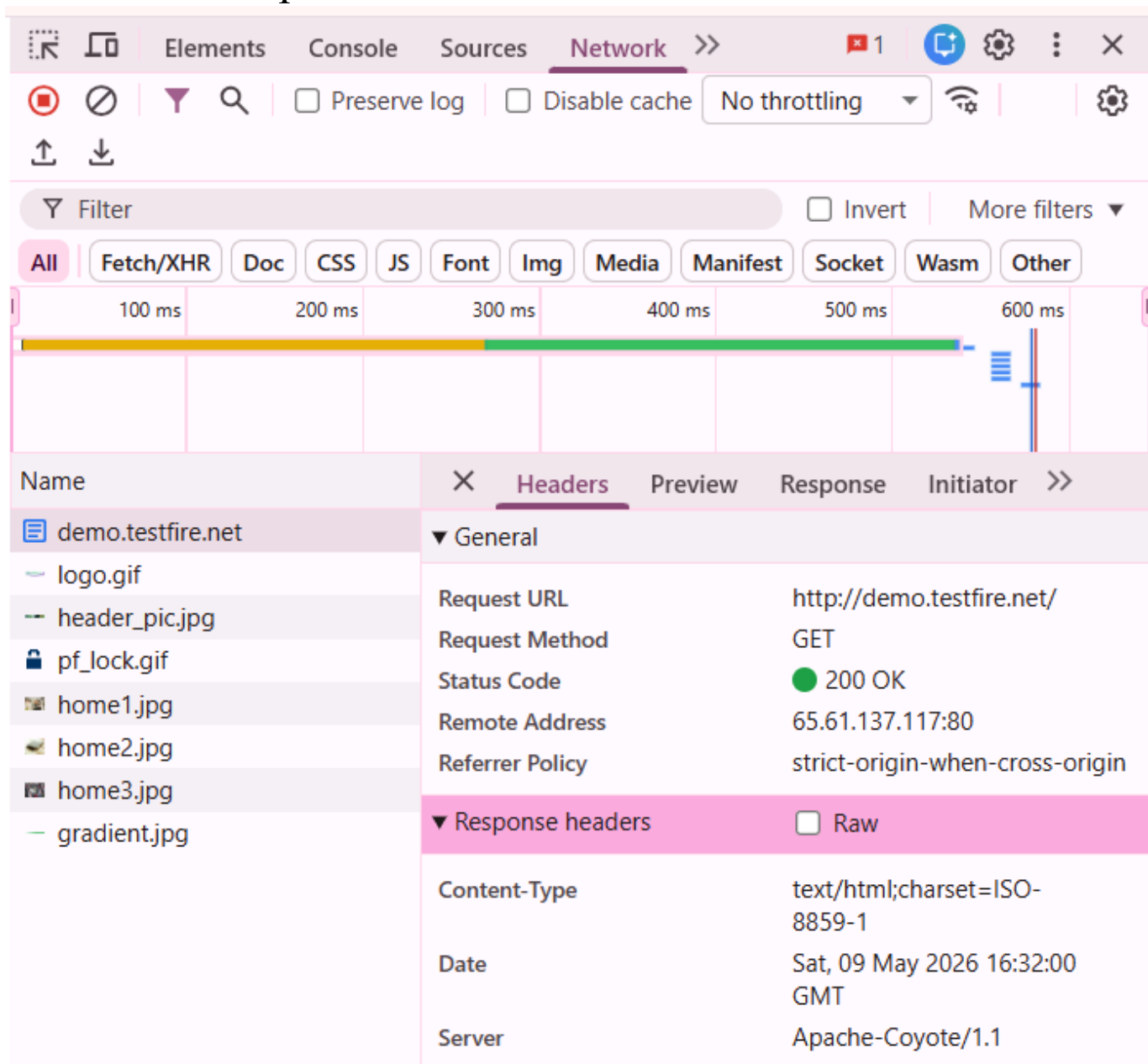
Description

Browser DevTools inspection confirmed that critical security headers are completely absent from all HTTP responses. Missing headers include Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, and Strict-Transport-Security.

Impact - Medium

System - <http://demo.testfire.net> (all pages)

Proof of Concept:



Recommendation:

Add these headers in server configuration:

- Content-Security-Policy: default-src 'self'
- X-Frame-Options: DENY
- X-Content-Type-Options: nosniff
- Strict-Transport-Security: max-age=31536000

Findings 6, 7, 8

Absence of Anti-CSRF Tokens (Medium)

Description

Forms across the application do not include CSRF tokens, allowing attackers to trick logged-in users into submitting unintended requests such as fund transfers.

Impact - Medium

System - All forms — <http://demo.testfire.net>

Recommendation: Add unique CSRF token to every state-changing form. Validate server-side.

Missing Anti-Clickjacking Header (Medium)

Description

The X-Frame-Options header is absent, allowing the site to be embedded in an iframe and used in clickjacking attacks against banking users.

Impact - Medium

System - All pages

Recommendation: Add X-Frame-Options: DENY to all HTTP responses.

Cookie Without SameSite Attribute (Medium)

Description

The JSESSIONID session cookie is set without the SameSite or Secure attributes, making it vulnerable to cross-site request forgery attacks.

Impact - Medium

System - JSESSIONID cookie

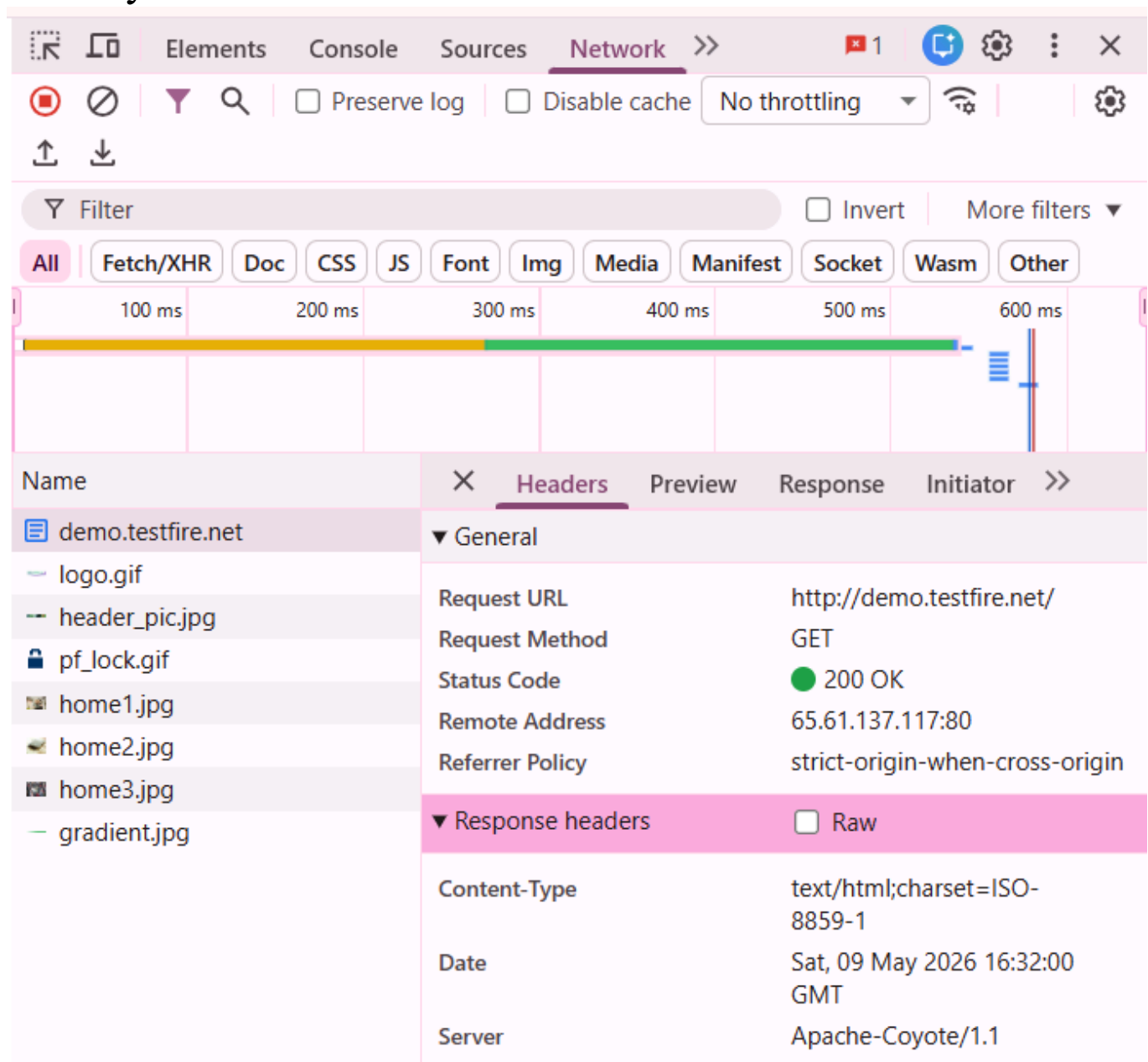


Figure-1.0

Recommendation: Set SameSite=Strict and Secure flag on all session cookies.

Findings 9, 10, 11

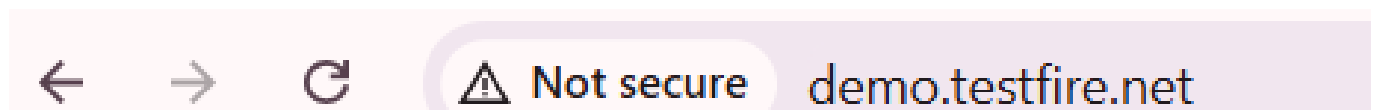
No HTTPS / TLS Encryption (Low)

Description

The entire site operates over plain HTTP. All data including login credentials is transmitted unencrypted and can be intercepted by anyone on the same network.

Impact - Low

System - <http://demo.testfire.net> (entire site)



Recommendation: Install free TLS certificate via Let's Encrypt. Redirect all HTTP to HTTPS.

Server Version Disclosure (Low)

Description

The Server response header reveals Apache-Coyote/1.1, giving attackers the exact software version to look up known exploits.

Impact - Low

System - HTTP response headers

For Figure refer:-Figure 1.0

Recommendation: Set ServerTokens Prod in Apache config to hide version details.

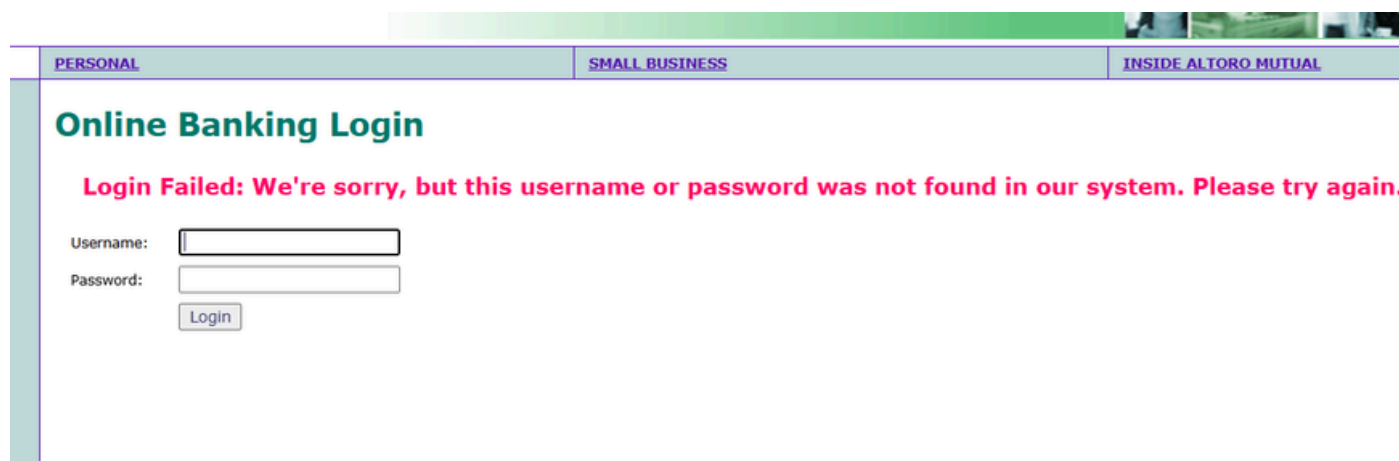
Verbose Login Error Message (Low)

Description

The login error message reveals whether the username exists in the system, enabling username enumeration attacks.

Impact - Low

System - <http://demo.testfire.net/login.jsp>



The screenshot shows a web application interface for online banking. At the top, there is a navigation bar with three tabs: "PERSONAL", "SMALL BUSINESS", and "INSIDE ALTORO MUTUAL". Below the navigation bar, the page title is "Online Banking Login". A red error message is displayed: "Login Failed: We're sorry, but this username or password was not found in our system. Please try again." Below the message, there are two input fields: "Username:" and "Password:". A "Login" button is positioned below the password field. The page has a light blue sidebar on the left.

Recommendation: Replace with generic message: "Invalid username or password. Please try again."

Network Scan Result(Nmap)

Findings:

- Port 80 (HTTP): Open
- Port 443 (HTTPS): Open
- Port 8080 (HTTP-Proxy/Web Service): Open
- Multiple ports are filtered by firewall

Impact:

- Open ports increase the external attack surface.
- Port 8080 may expose additional web applications or administrative services.
- Unpatched web services such as Apache Tomcat (Coyote JSP Engine) may be vulnerable to known exploits.
- HTTP service on port 80 may allow unencrypted communication.

Recommendations:

- Restrict unnecessary open ports using firewall rules.
- Disable unused services and administrative interfaces.
- Enforce HTTPS and redirect HTTP traffic securely.
- Regularly update and patch Apache Tomcat and associated web services.
- Continuously monitor exposed services for vulnerabilities and suspicious activity.

```
C:\WINDOWS\system32\cmd. x + v
Microsoft Windows [Version 10.0.26200.8246]
(c) Microsoft Corporation. All rights reserved.

C:\Users\Nishanth N Naik>nmap demo.testfire.net
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-10 14:17 +0530
Nmap scan report for demo.testfire.net (65.61.137.117)
Host is up (0.32s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https
8080/tcp   open  http-proxy
8443/tcp   closed https-alt

Nmap done: 1 IP address (1 host up) scanned in 22.73 seconds

C:\Users\Nishanth N Naik>
```

Security Weakness Summary

Default Credentials Successfully logged in with admin/admin. No lockout, no MFA, no CAPTCHA on login page.

SQL Injection Login form vulnerable to SQL injection via uid parameter. Full database access possible.

Cross-Site Scripting Search bar and feedback form vulnerable to reflected XSS confirmed by both manual testing and OWASP ZAP automated scan.

Missing Security Headers All standard security headers absent — CSP, HSTS, X-Frame-Options, X-Content-Type-Options.

No Encryption Entire application runs on HTTP. All credentials and session data transmitted in plain text.

PII Exposure Credit card numbers and sensitive personal data found in HTTP responses by ZAP passive scan.

The screenshot displays the Burp Suite application interface. The top section shows the Site Map, which is organized into a tree structure. Under the 'Contexts' tab, the 'Default Context' is selected. The 'Sites' tab is active, showing a list of sites. The first site is 'https://firefox-settings-attachments.cdn.mozilla.net'. The second site is 'https://firefox.settings.services.mozilla.com'. The third site is 'http://demo.testfire.net', which is expanded to show a list of resources. These resources include 'GET:/' (a folder icon), 'Documents' (a folder icon), 'GET:Privacypolicy.jsp(sec,template)' (a document icon), 'admin' (a folder icon), 'altoro' (a folder icon), 'api' (a folder icon), 'GET:cgi.exe' (a document icon), 'GET:default.jsp' (a document icon), and 'GET:default.jsp(content)' (a document icon). Below the Site Map, there is a toolbar with icons for 'History', 'Search', 'Alerts', 'Output', and 'Spider'. The 'Alerts' tab is selected, showing a list of alerts. The list is titled 'Alerts (22)' and contains 22 items. The first five items are 'Cross Site Scripting (Reflected) (3)', 'PII Disclosure (5)', 'SQL Injection (2)', 'Absence of Anti-CSRF Tokens (3)', and 'Content Security Policy (CSP) Header Not Set (Systemic)'. The remaining items are 'Cross-Domain Misconfiguration', 'Missing Anti-clickjacking Header (Systemic)', 'Sub Resource Integrity Attribute Missing', 'Application Error Disclosure', 'Cookie without SameSite Attribute (3)', 'Cross-Domain JavaScript Source File Inclusion', 'In Page Banner Information Leak', and 'Information Disclosure - Debug Error Messages (2)'. Each item is preceded by a folder icon.

Contexts

- Default Context

Sites

- > https://firefox-settings-attachments.cdn.mozilla.net
- > https://firefox.settings.services.mozilla.com
- ✓ http://demo.testfire.net
 - GET:/'
 - > Documents
 - GET:Privacypolicy.jsp(sec,template)
 - > admin
 - > altoro
 - > api
 - GET:cgi.exe
 - GET:default.jsp
 - GET:default.jsp(content)

History Search Alerts Output Spider

Alerts (22)

- > Cross Site Scripting (Reflected) (3)
- > PII Disclosure (5)
- > SQL Injection (2)
- > Absence of Anti-CSRF Tokens (3)
- > Content Security Policy (CSP) Header Not Set (Systemic)
- > Cross-Domain Misconfiguration
- > Missing Anti-clickjacking Header (Systemic)
- > Sub Resource Integrity Attribute Missing
- > Application Error Disclosure
- > Cookie without SameSite Attribute (3)
- > Cross-Domain JavaScript Source File Inclusion
- > In Page Banner Information Leak
- > Information Disclosure - Debug Error Messages (2)